

Vulnerability Assessment Report

Date: 2026-05-03
Analyst: marshall_c

[SYSTEM DESCRIPTION]

The target infrastructure consists of a high-performance Linux-based server (128GB RAM) hosting a MySQL database management system. The environment utilizes IPv4 networking and currently employs SSL/TLS for encrypted connections. This server is the primary repository for customer data, marketing campaigns, and performance analytics.

[SCOPE]

This assessment focuses exclusively on the **Access Control mechanisms** of the database system. The analysis evaluates risk over a three-month operational window, utilizing the **NIST SP 800-30 Rev. 1** framework to guide the risk assessment process.

[PURPOSE]

The database server is a centralized asset critical for managing large-scale customer and marketing data. Securing this system is essential to ensure the continuity of marketing operations and to maintain the confidentiality and integrity of proprietary analytic data. Failure to secure this asset would result in significant operational disruption and loss of competitive advantage.

[RISK ASSESSMENT]

Formula: Likelihood (1-3) x Severity (1-3) = Risk Score (1-9)

Threat Source	Threat Event	Likelihood	Severity	Risk Score
Hacker	Exfiltration of sensitive information	3	3	9

Employee	Disruption of mission-critical operations	2	3	6
Customer	Unauthorized alteration/deletion of data	1	3	3

[APPROACH]

The assessment utilized a qualitative methodology to evaluate data storage and management procedures. Threat sources and events were selected based on the high probability of exploitation due to the information system's current open-access configuration. Severity rankings were weighed against the potential impact on day-to-day operational stability and regulatory compliance.

[REMEDIATION STRATEGY]

To secure the environment and mitigate the identified risks, the following controls are recommended:

- **AAA Framework:** Implement centralized Authentication, Authorization, and Auditing to ensure strict user accountability.
- **Access Hardening:** Deploy Role-Based Access Control (RBAC) and Multi-Factor Authentication (MFA) to enforce the Principle of Least Privilege.
- **Network Security:** Transition fully to TLS for data-in-motion and implement **IP Allow-listing** to restrict database access to corporate office ranges, effectively closing the public-facing vulnerability.

[OPERATIONAL NOTES]

Leaving a production database open to the public is a critical vulnerability. By shifting from a public-access model to a hardened, authenticated infrastructure using NIST standards, the organization significantly reduces its attack surface while ensuring that only authorized specialists can interact with sensitive data.